

Attested Provenance Architecture (APA)

An attribute-agnostic trust architecture for data-centric policy enforcement, with security classification as the reference instance

James Patrick CITP MBCS

July 2026

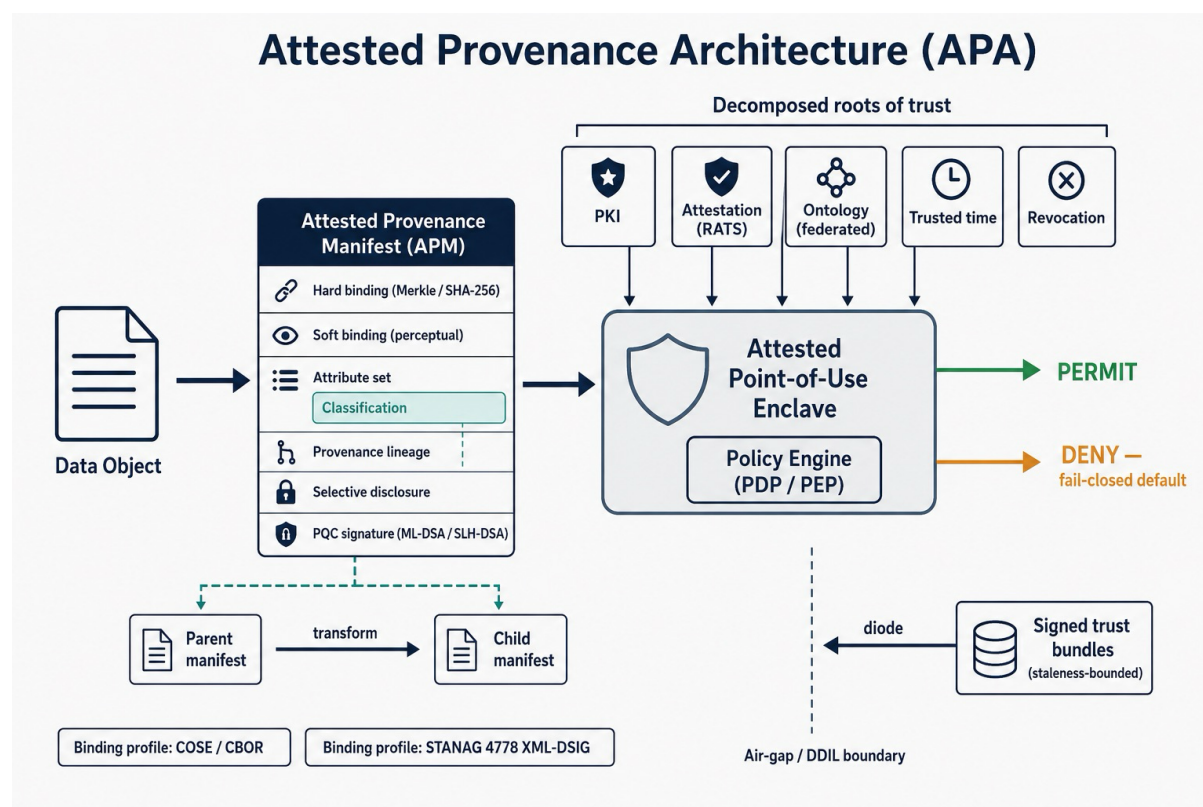


Figure 1 Reference architecture - v0.1

Status of this document

This is a reference architecture, not a standard and not a position paper. It defines an object model, manifest schema, trust model, lifecycle, threat model, policy-evaluation model, and the federation, revocation and disconnected-operation behaviours needed to build interoperable implementations. It is written to be built from and argued against at the level of components. Intended for publication with licence conditions.

The architecture is deliberately **attribute-agnostic**: it governs any policy-relevant attribute an object may carry. **Security classification is the reference instance** used throughout to make the abstract concrete, and is the instance with an existing standards hook (NATO STANAG 4774/4778) and a real operational customer. The discipline of this document is to *generalise the mechanism and narrow the proof*: the architecture is general; the worked, defended instance is classification.

1. The Reframe

Prior work on embedded classification asks: *how do we cryptographically bind a label to data?* That question is substantially solved and standards bodies are already moving it to post-quantum signatures. It is also the wrong question, because it treats classification as a property of a document at rest.

This architecture asks a different question: *how does a policy marking remain trustworthy and enforceable after the data has been transformed, copied, excerpted, aggregated, moved across domains, and shared across a coalition?* That is not a document-marking problem. It is a **distributed-systems problem** - and reframing it as one is the central contribution, because it aligns classification with where trusted computing, confidential computing, remote attestation, content provenance and zero-trust are already heading, and lets classification inherit their momentum rather than fight the current alone.

The consequences of the reframe are six architectural shifts:

1. **Classification becomes provenance.** The object model moves from `object → label` to `object → history → policy state`. A marking is not a stamp; it is a state derived from a signed lineage.
2. **Enforcement moves to attested compute.** Signatures never enforced anything. The enforcement boundary becomes an attested policy engine - measured boot, remote attestation, confidential compute - evaluated at the point of use.
3. **Policy state becomes dynamic.** Classification depends on aggregation, context, operational phase, releasability, coalition membership and time. The architecture models declared transitions as a state machine and is honest about the emergent ones it cannot evaluate locally.
4. **Provenance survives transformation.** The lineage and soft-binding constructs pioneered in content provenance (C2PA) are applied to policy attributes - borrowed, not reinvented.
5. **Trust is decomposed.** One fuzzy assumption ("trust everyone who touches the data") is inverted into five independently measurable, independently evolvable engineering problems: trust the PKI, the attestation, the ontology, the time source, the revocation infrastructure. This is the shift from security marketing to systems engineering.
6. **It works disconnected.** Commercial provenance assumes connectivity - online trust lists, reachable timestamp authorities, live revocation. This architecture is designed to hold in air-gapped and DDIL conditions. That is the defence-distinctive property and the hardest part.

Contribution 5 (dependency inversion) and contribution 6 (disconnected operation) carry the weight of this document. They are what make the architecture credible as systems engineering and distinct from a defence re-skin of existing provenance work.

2. Scope and Non-goals

In scope: the object and manifest model; the trust and attestation model; policy evaluation; lifecycle and revocation; federation; disconnected operation; and the threat model. Classification is specified as a worked profile.

Explicit non-goals. This architecture does **not** provide confidentiality of the payload - that is an orthogonal concern met by encryption (ML-KEM for key establishment where post-quantum confidentiality is required) and is out of scope except where the manifest itself must be protected (§7.5). It does **not** solve emergent aggregation (§9.3) - it bounds and flags the problem rather than claiming to evaluate it. It does **not** replace cross-domain content inspection on ingress (§13.4). And it does **not** propose a universal twelve-attribute ontology; it proposes an attribute-agnostic *mechanism* and defends a single instance.

3. Architectural Principles

Point-of-use enforcement. A policy decision is meaningful only where and when data is used, by an engine whose integrity can be attested. Markings evaluated anywhere else are advisory.

Fail-closed. Any failure - broken binding, unverifiable attestation, unresolvable attribute, stale trust material beyond its bound - resolves to the most restrictive available treatment, never the least.

Attribute-agnostic mechanism. The manifest, signature, lineage and policy-evaluation machinery are indifferent to which attribute they carry. Classification, export control, privacy basis, retention, evidential weight, AI-generation lineage and releasability are all instances of one mechanism. Implementations **MUST** support classification; they **MAY** support others through the same machinery.

Dependency inversion. The architecture deliberately decomposes trust into named roots (§7) so each can be measured, assured and replaced independently. No component is asked to trust another opaquely.

Disconnected-first. Connectivity is treated as an optimisation, not an assumption. Every trust-freshness mechanism has a defined offline behaviour and an explicit, signed staleness bound.

4. Object Model

The unit of governance is the **object**: a bounded piece of information (a file, a record, a message, a fragment). Each object is associated with an **Attested Provenance Manifest (APM)** that is cryptographically bound to it.

The conceptual shift is from a label attached to an object to a *policy state derived from a history*:

object → provenance chain (lineage of manifests) → evaluated policy state

An object's current policy state is not stored as a stamp; it is **computed** at point-of-use by evaluating the object's manifest and its ancestor chain against the applicable policy and the current trust context (time, revocation status, subject clearance, coalition membership). Two objects with identical bytes may have different policy states if their provenance differs; one object may have different states at different times or for different subjects. This is intentional and is the property static labelling cannot express.

5. Manifest schema (APM)

The APM is a signed structure binding a set of policy attributes and a provenance lineage to a specific object. It is format-agnostic with two normative binding profiles (§6). Its logical structure:

- **Object binding (hard)**. One or more cryptographic hashes over the object's canonicalised bytes (SHA2-256 baseline), organised in a Merkle-style tree so sub-objects can be individually addressed. Detects any post-signing alteration.
- **Object binding (soft)**. Optional perceptual fingerprints and/or watermarks that allow a manifest to be re-associated with content whose bytes have changed (transcoded, re-encoded, excerpted). Borrowed directly from C2PA soft bindings. A soft binding **MUST NOT** be used where a hard binding is required; it supports survivability, not integrity.
- **Attribute set**. An open set of typed policy attributes. Each attribute carries a type URI, a value, the asserting authority, an assurance/confidence indicator, and an optional validity condition (time- or event-bounded). **Classification** is the reference attribute type; its value references a classification policy identifier and level per STANAG 4774 syntax (see §5.1).
- **Provenance lineage**. References to parent manifest(s) and the transformation that produced this object (the C2PA ingredient/action pattern), so policy state can propagate through derivation.
- **Selective-disclosure envelope**. Salted, individually hashed attribute commitments allowing a relying party to be shown only the attributes it is entitled to resolve (§7.5) - so the manifest does not itself leak sensitive markings.

- **Freshness block.** Signed timestamp and, where available, revocation-freshness evidence, each carrying an explicit staleness bound for disconnected evaluation (§12).
- **Signature block.** One or more detached signatures over the above (§6), with algorithm agility and support for a hash-based archival profile (§6.2).

5.1 Classification as the Worked Attribute

The classification attribute instantiates the generic attribute type as: `{policy-id, classification-level, categories, releasability, caveats}` using STANAG 4774 confidentiality-label syntax as the value schema, asserted by a national or coalition originating authority, with an optional validity condition expressing scheduled declassification or event-conditional downgrade. Everything else in the manifest - binding, lineage, attestation, evaluation - is identical to any other attribute. That identity is the point: classification is not special machinery, it is the first well-specified instance of general machinery.

6. Binding profiles and cryptography

The architecture separates the manifest *structure* from the *binding profile* used to sign and embed it, so it can meet both NATO-interoperability and modern-embedded needs.

6.1 Two normative profiles

- **XML-DSIG profile.** Aligns with STANAG 4778's existing binding mechanism (W3C XML digital signatures). This is the interoperability bridge into NATO systems. Because 4778 binding profiles are explicitly versioned under a stable canonical identifier, a post-quantum profile is the standard's own designed extension path - not a competing scheme.
- **COSE/CBOR profile.** Aligns with the content-provenance world (COSE signatures over CBOR, JUMBF-style embedding). This is the efficient, embeddable profile for edge, sensor and modern data formats.

An APM is semantically identical across both profiles; a gateway can re-express one as the other without changing policy meaning.

6.2 Algorithm Selection and the Archival Profile

Signatures are algorithm-agile. The rationale for post-quantum signing here is **forgery longevity**, not confidentiality: a classified record must resist signature forgery for its full retention life, or an adversary with a future cryptographically-relevant quantum computer could forge an authority's signature to re-mark TOP SECRET as UNCLASSIFIED, or inject false high-assurance markings.

- **Operational profile:** ML-DSA (FIPS 204) where signature size and verification cost dominate and retention horizons are shorter. This aligns with the mainstream provenance direction of travel.
- **Archival profile:** SLH-DSA (hash-based, FIPS 205) for long-retention classified material, accepting larger signatures in exchange for the most conservative available security assumption. This is a deliberate divergence from commercial provenance, whose planned post-quantum path is ML-DSA only with no hash-based scheme - a reasonable choice for a content-authenticity horizon and the wrong one for a fifty-year classified one.

Per-object signing is the design point. Per-packet signing of data-in-motion is explicitly out of scope: post-quantum signature sizes and per-packet verification cost will not hold line rate.

7. Trust Model

The architecture adopts the RATS (Remote Attestation Procedures, RFC 9334) role separation and generalises it: **Attesters** (endpoints producing evidence of their own integrity), **Verifiers** (appraising that evidence against reference values), and **Relying Parties** (the policy engines consuming appraisal results to make enforcement decisions), with **Endorsers** and **Reference-Value Providers** supplying the ground truth.

The load-bearing move is the decomposition of trust into five named, independently assurable roots.

7.1 Trust the PKI

The signing and certificate infrastructure for attribute authorities. Assurable through conventional PKI governance, with the sovereignty constraint that the root **MUST** be nationally or coalition-controlled - a national classification regime cannot be rooted in a foreign commercial signing key.

7.2 Trust the Attestation

The evidence that the point-of-use policy engine is running known, unmodified code in a known state (measured boot, remote attestation, confidential compute). This is what converts an advisory label into an enforceable one. The attestation root of trust is subject to the same sovereignty constraint as the PKI; Arm CCA-style architectures with the potential for a sovereign attestation root are preferable to schemes rooted solely in a foreign silicon vendor's key.

7.3 Trust the Ontology

The agreed, machine-readable mapping of attribute values across authorities and nations (§10). This is the least mature root and the one that has historically killed

coalition projects. It is named as a first-class trust dependency precisely so it is engineered, versioned and governed rather than assumed.

7.4 Trust the Time

A trustworthy time source for evaluating validity conditions and revocation freshness - including in GNSS-denied, air-gapped conditions where an external time authority is unreachable (§12). Attested, holdover-capable, tamper-evident time is a dependency, not a given.

7.5 Trust the Revocation

The ability to know that a signature, attribute assertion, or authority credential has been withdrawn - including offline (§11). The selective-disclosure envelope (§5) is governed here: a relying party resolves only the attributes its clearance and need-to-know entitle it to, so the manifest does not become an intelligence leak (§13.1).

Each root is measurable, can fail independently, and can evolve independently. That is the dependency inversion, and it is the architecture's strongest systems-engineering claim.

8. Policy-evaluation Model

Enforcement follows the ABAC reference model (NIST SP 800-162 / XACML roles): a **Policy Enforcement Point (PEP)** intercepts the access or transformation; a **Policy Decision Point (PDP)**, running in an attested environment, evaluates; **Policy Information Points (PIPs)** supply context (subject clearance, coalition membership, time, revocation status, attestation appraisal); a **Policy Administration Point (PAP)** governs the policy set.

The PDP evaluates the object's manifest and lineage, resolves each attribute against applicable policy, and returns a decision (permit / deny / permit-with-obligation, e.g. redact, transform, watermark). Because the mechanism is attribute-agnostic, the PDP evaluates classification, export control, privacy basis and any other carried attribute *simultaneously and by the same machinery* - the object is released only if every policy dimension permits. Classification is one dimension in a multi-attribute decision, which is exactly the "operating system for trusted information" generalisation, kept disciplined by proving it on classification first.

Signatures are inputs to this decision, never the decision itself. A valid signature answers "is this marking authentic and intact?"; the PDP answers "what is permitted, here, now, for this subject?".

9. Lifecycle and the classification state machine

9.1 Creation

An originating authority asserts the initial attribute set, binds it (hard + optional soft) to the object, and signs. For classification, this is the point of origination marking.

9.2 Transformation and Declared Transitions

When an attested environment transforms an object, it emits a new manifest referencing its parent(s) and the action performed, propagating policy state through derivation. Declared transitions - scheduled declassification, event-conditional downgrade ("SECRET until operation X completes"), retention expiry - are modelled as a **state machine** over the attribute's value, evaluated at point-of-use against trusted time and event evidence. This declared-transition state machine is publishable in its own right, because almost all deployed systems wrongly treat classification as static.

9.3 Emergent Transitions - the Honest Limit

Aggregation (the mosaic problem - two UNCLASSIFIED facts combining to SECRET) is an **emergent** transition and a global property of everything a subject has seen. It cannot be evaluated locally at a single point-of-use from a single object's manifest. This architecture does not claim to solve it. It bounds it: the PDP can flag potential aggregation when a subject accumulates objects sharing categories, and can apply conservative obligations, but true aggregation inference is an open research problem (§16) and is stated as such. Claiming a state machine for declared transitions is defensible; claiming one for emergent aggregation would not be.

10. Federation and the Ontology Problem

Cross-domain is cross-*trust*-domain. Nation A's TOP SECRET, nation B's SECRET REL NATO, and a coalition's COSMIC TOP SECRET are not interchangeable, and releasability and caveats are the real governance surface. The architecture requires a **federated ontology**: a versioned, signed, machine-readable set of attribute-value equivalences and release rules, with each nation asserting its own values and agreed mappings between them.

This is named as the single biggest technical risk in the whole architecture - and, ironically, the reason it is worth pursuing, because nobody has solved it. The disciplined position is: the *mechanism* for carrying and evaluating federated attributes is general; the *proof* is a classification ontology across a defined coalition, not a universal ontology across all attributes and all parties. A twelve-attribute grand unification would die exactly here. Solve the classification federation for one coalition first; generalise once it holds.

11. Revocation and Re-classification

Attribute assertions are mutable in ways signatures are not: labels get downgraded, corrected after spillage, declassified on schedule, or invalidated when an authority key is compromised. The architecture therefore requires a revocation and re-assertion mechanism distinct from the immutable signature: a signed, versioned statement that a prior assertion is superseded, resolvable at point-of-use.

This inherits the unsolved problem of **revocation in disconnected environments** (§12). The architecture does not pretend to have closed it; it requires that every relying party evaluate revocation freshness against an explicit, signed staleness bound and fail closed when that bound is exceeded.

12. Disconnected and DDIL Operation

This section is the defence-distinctive core. Commercial provenance assumes reachable trust lists, timestamp authorities and revocation endpoints. Defence data lives in air-gapped enclaves and at the DDIL edge, where none of that is reachable. The architecture makes connectivity an optimisation and defines offline behaviour for every freshness-dependent mechanism.

- **Trust material** (trust lists, ontology versions, revocation snapshots) is distributed as signed, versioned bundles that can cross an air gap or diode, each carrying its own validity window. A relying party evaluates against the freshest bundle it holds and treats staleness explicitly.
- **Time** is provided by an attested, holdover-capable, tamper-evident local source, so validity conditions and revocation freshness can be evaluated without an external authority. Where time crosses a one-way link, the irreducible staleness of that link is represented as an explicit, signed bound rather than assumed to be zero.
- **Staleness is a first-class, signed value**, not a hidden assumption. Every offline decision is made against a known "trust material no older than T" bound, and exceeding the bound fails closed.
- **Cross-domain interplay**: a verifiable manifest lets a cross-domain guard make a fast release decision by verifying the binding and evaluating policy, rather than inspecting every byte - but only for data originating inside the trusted labelling regime (§13.4).

Getting disconnected operation right is what separates this from a re-skin of C2PA. It also drags in trusted time and disconnected revocation as named dependencies - which is honest, and which is why the dependency inversion (§7) matters: these are nameable, fundable problems, not hand-waving.

13. Threat Model

The architecture assumes a capable adversary with knowledge of the design (Kerckhoffs) and, in places, physical access.

13.1 The Label is Intelligence

A marking in clear ("this object is TS//SCI") is targeting data even when the payload is unreadable. *Mitigation*: the selective-disclosure envelope (§5, §7.5) - salted per-attribute commitments so a relying party resolves only what it is entitled to, and the manifest does not broadcast its most sensitive attributes.

13.2 Adversary-signed Content

An adversary will happily sign malicious content with their own perfectly valid key. *Mitigation*: trust is anchored in *whose* signature it is, via the federated PKI and ontology; a valid signature from an untrusted authority yields no trust. This is why signature validity is an input, not a decision (§8).

13.3 Compromised or Non-cooperating Endpoint

A malicious endpoint strips or ignores the manifest. *Mitigation*: enforcement lives in the attested PDP/PEP (§7.2). Without valid attestation the environment is not trusted to hold data, and fail-closed applies. This is the mechanism's hard dependency and its honest limit: no attestation, no enforcement.

13.4 Ingress Asymmetry

Signed provenance accelerates egress and internal flows for trusted-origin data; it does **not** replace content inspection on *ingress* of untrusted data, per §13.2. Conflating the two would be a serious and exploitable error, and is called out explicitly so implementers do not make it.

13.5 Rollback and Replay of Trust Material

An adversary presents stale trust material (an un-revoked snapshot, an expired ontology) to obtain a more permissive decision. *Mitigation*: signed staleness bounds and monotonic versioning of trust bundles; exceeding the bound fails closed (§12).

13.6 Soft-binding Evasion

Perceptual fingerprints and watermarks are attackable (adversarial evasion, false matches). *Mitigation*: soft bindings support survivability only, never integrity or enforcement (§5); a policy decision never rests on a soft binding alone. Their false-match and evasion characteristics become the system's characteristics and must be measured, not assumed.

13.7 Attestation and Supply-chain Root Compromise

If the attestation or PKI root is compromised at manufacture or issuance, downstream trust collapses. *Mitigation*: sovereign roots (§7.1–7.2), heterogeneous verification where feasible, and treating the root as the highest-value protection target in the whole system.

14. Worked Example: an Object Through its Life

A national imagery analyst creates a report. The originating authority asserts a classification attribute (SECRET, REL NATO, with a caveat) plus a retention attribute and an AI-generation-lineage attribute, binds them hard to the report and soft to its embedded imagery, and signs with the operational (ML-DSA) profile. The report is transformed - a paragraph excerpted into a coalition briefing - by an attested workstation, which emits a child manifest referencing the parent and the excerpt action; the classification propagates through the lineage rather than being lost. At a cross-domain boundary, the guard verifies the binding and evaluates release policy against the federated ontology, permitting release to a coalition partner whose national equivalence for "SECRET REL NATO" is resolved through the signed ontology mapping; because the data originated inside the trusted regime, the guard makes a fast binding-verification decision rather than deep content inspection. Six months later a scheduled-declassification validity condition fires; the point-of-use PDP, evaluating against attested local time in a disconnected enclave, resolves the object's current classification state to UNCLASSIFIED - no online authority required. Throughout, a subject cleared only to see the classification attribute never resolves the AI-lineage attribute, which is withheld by the selective-disclosure envelope.

15. Novelty and positioning

Conceded, explicitly: post-quantum signatures, content provenance, soft bindings, ABAC and remote attestation are all prior art. This architecture invents none of them.

Claimed:

1. **Classification (and policy attributes generally) reframed as a distributed-systems problem** - object → history → evaluated state - rather than document marking.
2. **Enforcement relocated to attested point-of-use compute**, making the signature an input rather than the control.
3. **A declared-transition classification state machine**, treating policy state as dynamic where deployed systems treat it as static.
4. **Application of provenance and soft-binding to policy-attribute propagation** under attestation.
5. **Dependency inversion** - one opaque trust assumption decomposed into five measurable, independently evolvable roots.
6. **Disconnected/DDIL operation** as a first-class property, distinguishing this from connectivity-assuming commercial provenance.

The strongest, most defensible framings are 5 and 6. The most publishable-in-isolation is 3.

16. Open Problems and Research Agenda

- **Federated ontology** across national classification regimes - the biggest risk, and the prize (§10).
- **Emergent aggregation inference** - evaluating the mosaic problem across a subject's accumulated exposure (§9.3).
- **Disconnected revocation** with bounded, provable freshness (§11–12).
- **Attested, tamper-evident trusted time** in GNSS-denied and air-gapped conditions (§7.4, §12).
- **Soft-binding robustness** - measured false-match and adversarial-evasion characteristics for policy-relevant content (§13.6).
- **Sovereign attestation and PKI roots** - the dependency shared with confidential computing and binary attestation, and the deepest of the five (§7).